CLOUDSHIELD TECHNOLOGIES

Third-Party Vendor

Security Risk Assessment

DataFlow Analytics, Inc.

Independent GRC Portfolio Project: Simulated Organization

Assessment ID	TPRM-001
Vendor	DataFlow Analytics, Inc.
Service	Cloud analytics and reporting platform
Business Criticality	High
Data Classification	Customer contact, account ID, and application-usage information
Assessment Decision	APPROVE WITH CONDITIONS
Linked Portfolio Risk	GRC-005: Inadequate Third-Party Security Review

1. Executive Assessment

CloudShield reviewed DataFlow Analytics as a high-criticality third party because the service connects to CloudShield's production application through an API and processes limited customer information. The assessment identified generally sound technical safeguards but material assurance, subcontractor-governance, and incident-notification gaps.

Final decision: APPROVE WITH CONDITIONS. Continued use is acceptable only if the required remediation actions below are completed and evidenced within the defined timelines.

2. Vendor & Data Profile

Assessment Attribute	Assessment Detail
Service purpose	Cloud analytics and reporting used by CloudShield.
Integration	API connection to CloudShield's production application.
Data processed	Customer names, business email addresses, account IDs, and application-usage information.
Excluded data	No payment-card data in the assessed use case.
Business criticality	High: disruption or compromise could affect reporting, operations, customer trust, or data confidentiality.
Last formal review	Two years ago.
Subprocessors	At least one subcontractor capable of processing CloudShield data was not present in the original vendor record.

3. Assessment Method

The review uses a portfolio-specific control questionnaire and evidence review. Each domain is rated Strong, Adequate, Needs Improvement, or Material Gap. Ratings reflect the simulated facts available for this assessment and are not a certification.

- Strong evidence indicates a mature control with no material gap identified.
- Adequate control is present and generally suitable, with minor or no noted weakness.
- Needs Improvement, control exists but evidence, governance, freshness, or execution should be strengthened.
- Material Gap; the issue could materially affect CloudShield's risk and requires remediation or explicit risk acceptance.

4. Security Questionnaire & Evidence Review

Domain	Vendor Response / Evidence	Rating	Finding	Required Follow-up
Identity & Access	MFA is used; access controls are documented.	Strong	No material issue identified in the simulated review.	Retain current evidence and reassess annually.
Encryption & Data Protection	Encryption is used in transit and at rest.	Strong	No material issue identified.	Confirm scope remains applicable to CloudShield data and integrations.
Vulnerability Management	Routine vulnerability scanning and annual penetration testing are reported.	Adequate	Technical testing exists; no specific overdue critical finding was identified for this vendor scenario.	Obtain current summary evidence during annual review.
Incident Response	Documented incident-response process exists; customer notification	Needs Improvement	CloudShield's desired contractual notification is 24 hours for applicable	Negotiate and document a 24-hour notification requirement or obtain formally

Domain	Vendor Response / Evidence	Rating	Finding	Required Follow-up
	commitment is within 72 hours after confirmed incidents.		incidents.	approved risk acceptance.
Business Continuity	Backups and disaster-recovery testing are reported.	Adequate	No material issue identified from available information.	Retain current test evidence during reassessment.
Independent Assurance	SOC 2 Type II report provided, but report is 18 months old.	Material Gap	Assurance evidence is stale for a high-criticality vendor.	Obtain a current SOC 2 Type II report or acceptable equivalent/bridge evidence and review exceptions.
Subprocessor Governance	Vendor uses a subcontractor that can process CloudShield data; it was not listed in CloudShield's original vendor record.	Material Gap	CloudShield has not completed due diligence on the newly identified subprocessor.	Identify subprocessor, data access, location, role, controls, and contractual flow-downs; complete due diligence before unconditional approval.
Security Governance	Vendor has documented	Adequate	Overall control environment	Complete annual risk-based

Domain	Vendor Response / Evidence	Rating	Finding	Required Follow-up
	security practices and provides requested evidence.		appears reasonably structured, subject to the assurance gaps above.	reassessment and track remediation.

5. Key Findings

Finding ID	Finding	Severity	Risk Statement
TPRM-F01	Stale Independent Assurance Evidence	High	DataFlow's SOC 2 Type II report is 18 months old. For a high-criticality vendor, CloudShield requires more current assurance before treating the vendor as fully approved.
TPRM-F02	Unreviewed Subprocessor	High	A subcontractor can process CloudShield data but was not included in the original vendor record. CloudShield has not yet assessed the subprocessor's risk or contractual safeguards.
TPRM-F03	Incident Notification Misalignment	Medium	DataFlow's stated notification period is 72

Finding ID	Finding	Severity	Risk Statement
			hours after confirmed incidents, while CloudShield's target contractual requirement is 24 hours for applicable security incidents.

6. Conditional Approval Requirements

Action	Requirement	Owner	Due	Acceptance Evidence
CAR-01	Current assurance evidence	Vendor Risk / Security Owner	30 days	Obtain current SOC 2 Type II or acceptable equivalent/bridge evidence; review exceptions and document disposition.
CAR-02	Subprocessor due diligence	Vendor Risk / Security Owner	30 days	Identify and assess the subcontractor; document data access, security controls, contractual flow-downs, and approval decision.
CAR-03	Incident-notification term	Legal / Security / Vendor Owner	45 days	Update contract/DPA to

Action	Requirement	Owner	Due	Acceptance Evidence
				require 24-hour notification for applicable security incidents, or document approved risk acceptance and compensating monitoring.
CAR-04	Annual reassessment cadence	Vendor Risk / Security Owner	Before next annual review	Record DataFlow as a high-criticality vendor and perform documented annual risk-based reassessment.

7. Decision & Risk Treatment

Decision: APPROVE WITH CONDITIONS. The vendor's existing technical controls reduce the need for immediate rejection, but the assurance and governance gaps are significant enough that unconditional approval is not appropriate.

- Risk treatment: Mitigate.
- Approval status: Conditional / remediation required.
- Reassessment: Required after remediation evidence is received and at least annually thereafter.
- Escalation trigger: If DataFlow refuses the required conditions, cannot provide adequate current assurance, or the subprocessor review identifies unacceptable risk, CloudShield should reconsider continued use and may reject or replace the vendor.

8. Analyst Conclusion

This assessment demonstrates a risk-based third-party decision rather than a binary pass/fail approach. CloudShield recognizes the vendor's existing technical safeguards while requiring targeted remediation for material governance gaps. The decision preserves business continuity while establishing accountable owners, deadlines, evidence requirements, and an escalation path.

Appendix A: Evidence Request Checklist

- Current SOC 2 Type II report, bridge letter, or acceptable equivalent assurance evidence.
- Security questionnaire and supporting control documentation.
- Current subprocessor list and notice/change process.
- Subprocessor due-diligence evidence and applicable contractual flow-downs.
- Incident-response plan and customer-notification commitment.
- Penetration-test executive summary and vulnerability-management evidence.
- Business continuity/disaster-recovery test summary.
- Encryption and access-control evidence relevant to CloudShield data.
- Contract/DPA security clauses and approved exceptions.
- Completed remediation actions and management approval.